

ТЕХНИЧЕСКИЙ КЕЙС

PII Airlock

Локальный privacy-gateway для облачных ИИ-запросов

Автор	AI-Danil
Дата	20 июля 2026
Статус	Воспроизводимый публичный демонстратор

Результат

Работающий двухконтурный gateway превращает документ и задачу в псевдонимизированный cloud payload, блокирует небезопасные кейсы и восстанавливает только точные токены текущей операции. Облако опционально; по умолчанию включён видимый dry-run. Проект не обещает абсолютную анонимность.

1. Проблема и архитектурное решение

Личному ИИ-ассистенту полезна облачная модель, но локальный контекст содержит имена, контакты, адреса, ID и ключи. Одна локальная LLM не является границей безопасности: она может пропустить сущность, выдумать подстроку, вернуть битый JSON или подчиниться инструкции внутри документа. Поэтому semantic detector дополнен детерминированными проверками.

2. Двухконтурный поток

- LM Studio получает задачу и документ только через 127.0.0.1 и возвращает сущности по JSON schema.
- Код принимает только точные подстроки, решает пересечения longest-first и создаёт `__PII_<nonce>_<TYPE>_<N>__`.
- Residual gate проверяет фактические исходящие поля. Ошибка модели/schema или известный остаточный секрет останавливает запрос.
- OpenAI опционален. Без ключа показывается точный payload; с ключом вызывается Responses API с `store: false`.
- Ответ облака недоверенный: неизвестный, изменённый или поддельный токен блокирует восстановление; mapping уничтожается.

The screenshot displays the PII Airlock web interface, which is designed to manage privacy boundaries for cloud LLM requests. The interface is dark-themed and includes a navigation bar at the top with the text "LOCAL → CLOUD → LOCAL".

The main header features the "PII Airlock" logo and a subtitle: "A local privacy boundary for cloud LLM requests. Raw values stay on this machine." A status indicator in the top right corner shows "LM Studio: reachable · Cloud: dry-run".

The interface is divided into several sections:

- LOCAL DETECTOR:** A dropdown menu is set to "Qwen 3.5 9B".
- TASK:** A text input field contains the instruction: "Write a concise, polite reply while preserving every PII token exactly."
- LOAD TXT / MD / DOCX / PDF:** A button labeled "Выберите файл" (Select file) is present, with a status "Файл не выбран" (File not selected).

The main content area is divided into four panels:

- 01 · LOCAL INPUT:** Titled "Original document", it shows a text snippet: "Contact Elena Morozova at elena.morozova@example.test or +7 999 123-45-67. Contract CN-2049 belongs to Northstar Lab."
- 02 · LOCAL DETECTION:** Titled "Detected types", it lists detected entities: "CONTRACT_ID × 1", "EMAIL × 1", "ORG × 1", "PERSON × 1", and "PHONE × 1".
- 03 · CLOUD PAYLOAD:** Titled "Pseudonymized text", it shows the sanitized version of the document: "Contact __PII_F8938AF4_PERSON_0001__ at __PII_F8938AF4_EMAIL_0001__ or __PII_F8938AF4_PHONE_0001__, Contract __PII_F8938AF4_CONTRACT_ID_0001__ belongs to __PII_F8938AF4_ORG_0001__."
- 04 · LOCAL RESTORE:** Titled "Final answer", it shows the result: "DRY RUN — sanitized payload was not sent because OPENAI_API_KEY is absent."

At the bottom of the interface, there is a status bar with "SAFE · DRY RUN" and three buttons: "Analyze locally", "Send sanitized payload", and "Destroy mapping".

Real local Qwen dry-run · synthetic values only

3. Доказательства вместо обещаний

Все цифры ниже получены в новом воспроизводимом запуске на 30 синтетических документах: 15 RU + 15 EN.

Метрика	Qwen 3.5 9B	Gemma 4 E4B
Разрешённые payload / 30	25	25
Контрольные утечки в разрешённых	0	0
Entity-level recall	0.6667	0.7593
Лишние значения для замены	5	4
Schema / exact-substring ошибки	4	0
Блокировки dataset release gate	1	5
Round-trip fidelity	26	30
Медиана / максимум	2.556 / 6.182 c	1.567 / 4.116 c

Интерпретация: обе модели экспериментальные. Dataset-only oracle не разрешал payload с известным контрольным значением. Ноль утечек среди разрешённых payload — доказательство только для этих fixtures, а не гарантия для неизвестных документов.

4. Созданные артефакты

- Python 3.11 Web UI, CLI и локальный API; mapping в памяти с TTL 10 минут.
- TXT, Markdown, DOCX и PDF с текстовым слоем; OCR/изображения/архивы и >20 000 символов блокируются в V1.
- 25 offline-тестов со stub: spans, overlap, tokens, TTL, форматы, timeout, prompt injection framing, логи и round trip.
- Полные README RU/EN, threat model, SECURITY.md, fixtures, per-case JSON, screenshot и GitHub Actions.
- Локальный выключенный адаптер Гоши с fail-closed; текущие тесты Гоши 27/27, сервис не перезапускался.

5. Риски и следующий эксперимент

Semantic PII всё ещё может быть пропущен; правила не являются универсальным DLP. Память процесса, внутренности LM Studio, OS swap и политика провайдера вне гарантии. Для рискованных документов нужен dry-run. Следующий эксперимент — расширить adversarial fixtures и улучшить semantic detection без ослабления exact-substring validation.